ZAP Scanning Report

Site: http://127.0.0.1:5000

Generated on Wed, 14 Oct 2026 19:18:09

ZAP Version: 2.17.0

ZAP by Checkmarx

Summary of Alerts

Risk Level	Number of Alerts
High	0
Medium	0
Low	1
Informational	7
False Positives:	0

Insights

Level	Reason	Site	Description	Statistic
Info	Informational	http://127.0.0.1:5000	Percentage of responses with status code 2xx	75 %
Info	Informational	http://127.0.0.1:5000	Percentage of responses with status code 4xx	25 %
Info	Informational	http://127.0.0.1:5000	Percentage of endpoints with content type text/html	100 %
Info	Informational	http://127.0.0.1:5000	Percentage of endpoints with method GET	83 %
Info	Informational	http://127.0.0.1:5000	Percentage of endpoints with method POST	16 %
Info	Informational	http://127.0.0.1:5000	Count of total endpoints	6

Summary of Sequences

For each step: result (Pass/Fail) - risk (of highest alert(s) for the step, if any).

Alerts

Name	Risk Level	Number of Instances
Server Leaks Version Information via "Server" HTTP Response Header Field	Low	Systemic
Authentication Request Identified	Informational	1
Non-Storable Content	Informational	Systemic
Sec-Fetch-Dest Header is Missing	Informational	3
Sec-Fetch-Mode Header is Missing	Informational	3
Sec-Fetch-Site Header is Missing	Informational	3
Sec-Fetch-User Header is Missing	Informational	3
User Controllable HTML Element Attribute (Potential XSS)	Informational	1

Alert Detail

Low	Server Leaks Version Information via "Server" HTTP Response Header Field
Description	The web/application server is leaking version information via the "Server" HTTP response header. Access to such information may facilitate attackers identifying other vulnerabilities your web/application server is subject to.
URL	http://127.0.0.1:5000
Node Name	http://127.0.0.1:5000
Method	GET
Parameter	
Attack	
Evidence	Werkzeug/3.1.9 Python/3.11.17
Other Info	
URL	http://127.0.0.1:5000/login
Node Name	http://127.0.0.1:5000/login
Method	GET
Parameter	
Attack	
Evidence	Werkzeug/3.1.9 Python/3.11.17
Other Info	
Instances	Systemic
Solution	Ensure that your web server, application server, load balancer, etc. is configured to suppress the "Server" header or provide generic details.
Reference	https://httpd.apache.org/docs/current/mod/core.html#servertokens https://learn.microsoft.com/en-us/previous-versions/msp-n-p/ff648552(v=pandp.10) https://www.troyhunt.com/shhh-dont-let-your-response-headers/
CWE Id	497
WASC Id	13
Plugin Id	10036

Informational	Authentication Request Identified
Description	The given request has been identified as an authentication request. The 'Other Info' field contains a set of key=value lines which identify any relevant fields. If the request is in a context which has an Authentication Method set to "Auto-Detect" then this rule will change the authentication to match the request identified.
URL	http://127.0.0.1:5000/login
Node Name	http://127.0.0.1:5000/login ()(password,username)
Method	POST
Parameter	username
Attack	
Evidence	password
Other Info	userParam=username userValue=ZAP passwordParam=password referer=http://127.0.0.1:5000/login
Instances	1
Solution	This is an informational alert rather than a vulnerability and so there is nothing to fix.
Reference	https://www.zaproxy.org/docs/desktop/addons/authentication-helper/auth-req-id/
CWE Id	
WASC Id	
Plugin Id	10111

Informational	Non-Storable Content
Description	The response contents are not storable by caching components such as proxy servers. If the response does not contain sensitive, personal or user-specific information, it may benefit from being stored and cached, to improve performance.
URL	http://127.0.0.1:5000
Node Name	http://127.0.0.1:5000
Method	GET
Parameter	
Attack	
Evidence	no-store
Other Info	
URL	http://127.0.0.1:5000/login
Node Name	http://127.0.0.1:5000/login
Method	GET
Parameter	
Attack	
Evidence	no-store
Other Info	
URL	http://127.0.0.1:5000/robots.txt
Node Name	http://127.0.0.1:5000/robots.txt
Method	GET
Parameter	
Attack	
Evidence	no-store
Other Info	
URL	http://127.0.0.1:5000/search
Node Name	http://127.0.0.1:5000/search
Method	GET
Parameter	
Attack	
Evidence	no-store
Other Info	
URL	http://127.0.0.1:5000/sitemap.xml
Node Name	http://127.0.0.1:5000/sitemap.xml
Method	GET
Parameter	
Attack	
Evidence	no-store
Other Info	
Instances	Systemic
Solution	The content may be marked as storable by ensuring that the following conditions are satisfied: The request method must be understood by the cache and defined as being cacheable ("GET", "HEAD", and "POST" are currently defined as cacheable) The response status code must be understood by the cache (one of the 1XX, 2XX, 3XX, 4XX, or 5XX response classes are generally understood) The "no-store" cache directive must not appear in the request or response header fields For caching by "shared" caches such as "proxy" caches, the "private" response directive must not appear in the response For caching by "shared" caches such as "proxy" caches, the "Authorization" header field must not appear in the request, unless the response explicitly allows it (using one of the "must-revalidate", "public", or "s-maxage" Cache-Control response directives) In addition to the conditions above, at least one of the following conditions must also be satisfied by the response: It must contain an "Expires" header field It must contain a "max-age" response directive For "shared" caches such as "proxy" caches, it must contain a "s-maxage" response directive It must contain a "Cache Control Extension" that allows it to be cached It must have a status code that is defined as cacheable by default (200, 203, 204, 206, 300, 301, 404, 405, 410, 414, 501).
Reference	https://datatracker.ietf.org/doc/html/rfc7234 https://datatracker.ietf.org/doc/html/rfc7231 https://www.w3.org/Protocols/rfc2616/rfc2616-sec13.html
CWE Id	524
WASC Id	13
Plugin Id	10049

Informational	Sec-Fetch-Dest Header is Missing
Description	Specifies how and where the data would be used. For instance, if the value is audio, then the requested resource must be audio data and not any other type of resource.
URL	http://127.0.0.1:5000
Node Name	http://127.0.0.1:5000
Method	GET
Parameter	Sec-Fetch-Dest
Attack	
Evidence	
Other Info	
URL	http://127.0.0.1:5000/robots.txt
Node Name	http://127.0.0.1:5000/robots.txt
Method	GET
Parameter	Sec-Fetch-Dest
Attack	
Evidence	
Other Info	
URL	http://127.0.0.1:5000/sitemap.xml
Node Name	http://127.0.0.1:5000/sitemap.xml
Method	GET
Parameter	Sec-Fetch-Dest
Attack	
Evidence	
Other Info	
Instances	3
Solution	Ensure that Sec-Fetch-Dest header is included in request headers.
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Sec-Fetch-Dest
CWE Id	352
WASC Id	9
Plugin Id	90005

Informational	Sec-Fetch-Mode Header is Missing
Description	Allows to differentiate between requests for navigating between HTML pages and requests for loading resources like images, audio etc.
URL	http://127.0.0.1:5000
Node Name	http://127.0.0.1:5000
Method	GET
Parameter	Sec-Fetch-Mode
Attack	
Evidence	
Other Info	
URL	http://127.0.0.1:5000/robots.txt
Node Name	http://127.0.0.1:5000/robots.txt
Method	GET
Parameter	Sec-Fetch-Mode
Attack	
Evidence	
Other Info	
URL	http://127.0.0.1:5000/sitemap.xml
Node Name	http://127.0.0.1:5000/sitemap.xml
Method	GET
Parameter	Sec-Fetch-Mode
Attack	
Evidence	
Other Info	
Instances	3
Solution	Ensure that Sec-Fetch-Mode header is included in request headers.
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Sec-Fetch-Mode
CWE Id	352
WASC Id	9
Plugin Id	90005

Informational	Sec-Fetch-Site Header is Missing
Description	Specifies the relationship between request initiator's origin and target's origin.
URL	http://127.0.0.1:5000
Node Name	http://127.0.0.1:5000
Method	GET
Parameter	Sec-Fetch-Site
Attack	
Evidence	
Other Info	
URL	http://127.0.0.1:5000/robots.txt
Node Name	http://127.0.0.1:5000/robots.txt
Method	GET
Parameter	Sec-Fetch-Site
Attack	
Evidence	
Other Info	
URL	http://127.0.0.1:5000/sitemap.xml
Node Name	http://127.0.0.1:5000/sitemap.xml
Method	GET
Parameter	Sec-Fetch-Site
Attack	
Evidence	
Other Info	
Instances	3
Solution	Ensure that Sec-Fetch-Site header is included in request headers.
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Sec-Fetch-Site
CWE Id	352
WASC Id	9
Plugin Id	90005

Informational	Sec-Fetch-User Header is Missing
Description	Specifies if a navigation request was initiated by a user.
URL	http://127.0.0.1:5000
Node Name	http://127.0.0.1:5000
Method	GET
Parameter	Sec-Fetch-User
Attack	
Evidence	
Other Info	
URL	http://127.0.0.1:5000/robots.txt
Node Name	http://127.0.0.1:5000/robots.txt
Method	GET
Parameter	Sec-Fetch-User
Attack	
Evidence	
Other Info	
URL	http://127.0.0.1:5000/sitemap.xml
Node Name	http://127.0.0.1:5000/sitemap.xml
Method	GET
Parameter	Sec-Fetch-User
Attack	
Evidence	
Other Info	
Instances	3
Solution	Ensure that Sec-Fetch-User header is included in user initiated requests.
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Sec-Fetch-User
CWE Id	352
WASC Id	9
Plugin Id	90005

Informational	User Controllable HTML Element Attribute (Potential XSS)
Description	This check looks at user-supplied input in query string parameters and POST data to identify where certain HTML attribute values might be controlled. This provides hot-spot detection for XSS (cross-site scripting) that will require further review by a security analyst to determine exploitability.
URL	http://127.0.0.1:5000/search?q=ZAP
Node Name	http://127.0.0.1:5000/search (q)
Method	GET
Parameter	q
Attack	
Evidence	
Other Info	User-controlled HTML attribute values were found. Try injecting special characters to see if XSS might be possible. The page at the following URL: http://127.0.0.1:5000/search?q=ZAP appears to include user input in: a(n) [input] tag [value] attribute The user input found was: q=ZAP The user-controlled value was: zap
Instances	1
Solution	Validate all input and sanitize output it before writing to any HTML attributes.
Reference	https://cheatsheetseries.owasp.org/cheatsheets/Input_Validation_Cheat_Sheet.html
CWE Id	20
WASC Id	20
Plugin Id	10031

Sequence Details

With the associated active scan results.